

Aetheris Therapeutics S.p.A. — Cybersecurity Gap Analysis

Documento Integrato di Valutazione della Postura di Sicurezza dell'Infrastruttura e Gap Analysis Consolidata per i 5 Domini Core: Identify, Protect, Detect, Respond, Recover.

CORE CATEGORY 1: IDENTIFY (ID)

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
Asset Management (ID.AM)	ID.AM-1: Dispositivi fisici censiti e tracciati regolarmente?	FAIL	L'IT gestisce un semplice foglio elettronico statico contenente numeri di serie, modelli e dettagli di garanzia dei soli laptop. Manca un CMDB automatizzato o integrato, né esiste un processo formale di revisione periodica per l'intera flotta di dispositivi aziendali.
	ID.AM-2: Piattaforme e applicazioni software censite?	FAIL	Non esiste un inventario centralizzato e aggiornato del software installato o dei servizi attivi. Si rileva l'assenza totale di controlli sullo Shadow IT o di verifiche sistematiche sui software autorizzati.
	ID.AM-3: Flussi di comunicazione e diagrammi di rete mappati?	PASS	Il team IT ha svolto un ottimo lavoro operativo, mantenendo diagrammi di rete chiari, dettagliati e costantemente aggiornati, che includono correttamente l'infrastruttura e l'ambiente cloud Microsoft Azure.
	ID.AM-4: Sistemi informativi esterni e SaaS catalogati?	FAIL	Aetheris Therapeutics S.p.A. si affida ampiamente ad applicazioni SaaS (come Microsoft Office 365 e piattaforme di ricerca esterne), ma non effettua alcuna catalogazione centralizzata o gestione del rischio verso terze parti. I contratti sono rivisti solo da procurement e finance, senza coinvolgere l'IT o la sicurezza.
	ID.AM-5: Asset prioritizzati in base alla classificazione dei dati?	FAIL	Non esistono policy di data governance né sistemi di classificazione delle informazioni. Di conseguenza, è impossibile prioritizzare gli asset aziendali e i server in base alla sensibilità o alla criticità strategica del dato trattato (es. formule e brevetti).
Business Environment (ID.BE)	ID.BE-1: Ruolo dell'organizzazione nella supply chain documentato?	FAIL	Non viene eseguita alcuna attività di Third-Party Risk Management. Non esiste documentazione formale che tracci o classifichi i fornitori esterni in base alla loro criticità per la catena di fornitura cyber.
	ID.BE-2: Posizione dell'azienda nelle infrastrutture critiche?	N/A	In base ai dati societari attuali, Aetheris Therapeutics S.p.A. opera nel settore biotecnologico/farmaceutico privato e non è formalmente classificata come infrastruttura critica nazionale o operatore di servizi essenziali.
	ID.BE-3: Missione e strategia di business chiaramente comunicate?	PASS	La direzione aziendale ha definito e comunicato a tutta l'organizzazione una visione commerciale e obiettivi di business estremamente chiari, focalizzati sulla ricerca, sviluppo e crescita di mercato.
	ID.BE-4: Funzioni critiche aziendali e dipendenze stabilite?	FAIL	Sebbene l'IT esegua ottimi controlli operativi (backup regolari, piani di continuità documentati e test di Disaster Recovery), manca una mappatura formale guidata dal business che colleghi le dipendenze tecnologiche alle funzioni aziendali critiche.

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
	ID.BE-5: Requisiti di resilienza e verifiche SLA/SOC definite?	FAIL	Non è mai stata condotta una Business Impact Analysis (BIA) formale per legare i requisiti di resilienza al business. Non si effettua alcuna due diligence sui report di sicurezza dei fornitori esterni o sulle garanzie dei servizi SaaS erogati.
Governance (ID.GV)	ID.GV-1: Politica formale di sicurezza delle informazioni istituita?	FAIL	È presente un'unica policy IT generica focalizzata sugli aspetti operativi. Manca completamente una Information Security Policy (ISP) formale e strutturata approvata dalla direzione.
	ID.GV-2: Ruoli e responsabilità cyber coordinati e assegnati?	FAIL	I ruoli di sicurezza non sono formalizzati né documentati. Le mansioni operative del cyber analyst e dei sistemisti di rete sono frammentate sotto l'IT, senza una funzione di sicurezza indipendente o linee di riporto dedicate.
	ID.GV-3: Requisiti legali e di privacy (GDPR) compresi e gestiti?	FAIL	L'assenza di policy sul trattamento dei dati, di un registro dei trattamenti e di criteri di data governance pone Aetheris Therapeutics S.p.A. in una condizione di palese non-conformità (Non-Compliance) rispetto ai requisiti del GDPR, esponendola a gravissimi rischi legali.
	ID.GV-4: Processi di governance che indirizzano il rischio cyber?	FAIL	Il Board di Aetheris Therapeutics S.p.A. e la direzione non hanno alcuna visibilità o supervisione formale sui rischi tecnologici e cyber. Il team di risk management interno si occupa esclusivamente di rischi finanziari o clinici classici.
Risk Assessment (ID.RA)	ID.RA-1: Scansioni e analisi delle vulnerabilità eseguite con regolarità?	FAIL	L'azienda ha acquistato uno scanner di vulnerabilità (Qualys), ma il team IT lo utilizza solo su base "ad-hoc". Le scansioni non sono schedate e mancano del tutto reportistica formale, metriche o piani strutturati di remediation/patching.
	ID.RA-2: Informazioni sulle minacce ricevute da feed/intelligence?	FAIL	Non è presente alcun programma di iscrizione a feed di Threat Intelligence o forum di condivisione delle informazioni (es. CERT). L'unico analista opera solo in modalità puramente reattiva ("antincendio").
	ID.RA-3: Minacce interne ed esterne identificate e documentate?	FAIL	Non viene eseguito alcun processo di identificazione formale o modellazione delle minacce e dei Threat Actors interessati alla proprietà intellettuale aziendale (formule chimiche e brevetti terapeutici).
	ID.RA-4: Impatti aziendali potenziali e probabilità identificati?	FAIL	L'assenza di una classificazione del valore degli asset e di una BIA strutturata rende impossibile quantificare l'impatto economico, operativo o reputazionale e la probabilità degli scenari di incidente cyber.
	ID.RA-5: Minacce e vulnerabilità usate per determinare il rischio?	FAIL	Non esiste alcuna metodologia formale o framework (es. ISO 27005) atto a combinare minacce, vulnerabilità e impatti per determinare il livello di rischio reale dei sistemi informativi.
	ID.RA-6: Risposte al rischio identificate e priorizzate?	FAIL	Mancando un framework di classificazione del rischio a monte, le azioni correttive e gli investimenti tecnologici non possono essere prioritizzati in base all'effettivo impatto sul business.
Risk Management Strategy (ID.RM)	ID.RM-1: Processo di risk management approvato dal management?	FAIL	Il top management non ha mai potuto validare o supportare formalmente un processo di gestione del rischio cyber semplicemente perché a livello organizzativo tale processo non è strutturato.

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
	ID.RM-2: Tolleranza al rischio definita tramite Risk Appetite?	FAIL	Aetheris Therapeutics S.p.A. non ha mai formalizzato, approvato o diffuso un documento di Cyber Risk Appetite Statement per stabilire le soglie massime di perdita tollerabili dal Board.
	ID.RM-3: Tolleranza al rischio basata su vincoli infrastrutturali?	N/A	Coerentemente con lo status dell'organizzazione, i requisiti specifici di tolleranza al rischio per le infrastrutture critiche nazionali non si applicano direttamente alle operazioni interne correnti.

CORE CATEGORY 2: PROTECT (PR)

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
Identity Management & Access Control (PR.AC)	PR.AC-1: Identità e credenziali degli utenti (e dispositivi) tracciate e gestite?	FAIL	Sebbene sia in uso Active Directory, non vi sono policy formali sulla complessità delle password o sulla gestione del ciclo di vita delle identità. Gli accessi sono concessi ed eseguiti meramente "su richiesta", aumentando il rischio di privilege creep.
	PR.AC-2: Accessi fisici ai dispositivi e ai siti protetti e gestiti?	FAIL	Nonostante la sorveglianza TVCC 24/7 nelle sedi, mancano controlli granulari (es. biometrici) per isolare i laboratori di ricerca sensibili. Si rileva l'assenza di registri formali di tracciamento per visitatori e fornitori esterni.
	PR.AC-3: Accessi remoti protetti (es. VPN, MFA)?	FAIL	È presente una soluzione VPN per il lavoro remoto, ma non è implementato il secondo fattore di autenticazione (MFA). L'accesso basato su sole credenziali statiche rappresenta una vulnerabilità critica.
	PR.AC-4: Gestione dei permessi basata sul principio del minimo privilegio?	FAIL	Manca totalmente una soluzione PAM. Le credenziali degli account amministrativi di alto livello (Admin) sono condivise stabilmente tra più membri senior dell'IT, azzerando l'accountability individuale.
	PR.AC-5: Integrità e segmentazione della rete aziendale attuata?	PASS	Ottima maturità operativa. La rete interna è segmentata tramite VLAN e protetta da firewall Palo Alto Next-Gen regolarmente configurati, aggiornati e sottoposti a verifica annuale. I diagrammi di rete includono accuratamente l'ambiente cloud Azure.
Awareness & Training (PR.AT)	PR.AT-1: Tutti i dipendenti ricevono formazione periodica sulla cybersecurity?	FAIL	La formazione si riduce a un singolo modulo introduttivo generico (induction) erogato via web solo al momento dell'assunzione. Mancano sessioni di retraining e campagne di phishing simulato.
	PR.AT-2: Gli utenti con privilegi elevati (Admin/IT) ricevono una formazione ad hoc?	FAIL	Non è previsto alcun percorso specialistico o avanzato per amministratori di sistema o gestori cloud; i profili senior sono equiparati agli utenti standard o esentati in base alla storicità in azienda.
	PR.AT-3: I partner terzi e i fornitori comprendono le loro responsabilità cyber?	FAIL	Non si effettua Third-Party Risk Management. I contratti dei fornitori sono vagliati solo da procurement e finance per gli aspetti commerciali, senza requisiti tecnici cyber.
	PR.AT-4: I Senior Executive e il Board sono formati e consapevoli del rischio cyber?	FAIL	Il top management non riceve briefing dedicati su minacce mirate (es. CEO Fraud). La governance aziendale è sorda alla cybersecurity e focalizzata esclusivamente sul rischio finanziario e clinico classico.
Data Security (PR.DS)	PR.DS-1: I dati a riposo (Data-at-Rest) sono protetti e cifrati di default?	FAIL	L'azienda delega la sicurezza interamente alla reputazione di Microsoft Azure e O365, ignorando il modello di responsabilità condivisa. Mancano attività di Data Discovery, classificazione dei dati e strumenti DLP sull'host.
	PR.DS-2: I dati in transito (Data-in-Transit) sono protetti da esfiltrazioni?	FAIL	La VPN cifra il canale di comunicazione, ma l'assenza totale di un DLP di rete e la mancanza di restrizioni hardware sulle porte USB consentono la copia e l'esfiltrazione in blocco di proprietà intellettuale.

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
	PR.DS-3: Gli asset sono gestiti formalmente durante il loro intero ciclo di vita?	FAIL	L'inventario hardware si basa su un foglio Excel statico focalizzato sulle sole garanzie dei laptop. Manca un processo formale di secure disposal o cancellazione certificata dei dischi rigidi dismessi.
	PR.DS-4: Sono implementate protezioni contro i data leak (programmi DLP)?	FAIL	Non esiste alcuna soluzione o programma di Data Loss Prevention. L'organizzazione soffre di una cecità completa sui flussi informatici, non potendo rilevare o bloccare trasferimenti anomali di file critici.
Information Protection Processes & Procedures (PR.IP)	PR.IP-1: Gli ambienti di sviluppo/test sono separati dalla produzione?	N/A	L'organizzazione non sviluppa software in-house e non ha programmatori interni; l'intera operatività aziendale poggia su servizi e piattaforme SaaS esterne.
	PR.IP-2: Viene mantenuta e applicata una configurazione di base sicura (Baseline)?	PASS	Il team IT applica con successo una procedura di standardizzazione tramite un'immagine SOE (Secure Operating Environment) aggiornata per il roll-out iniziale di Windows su tutti i laptop.
	PR.IP-3: I processi di controllo dei cambiamenti (Change Management) sono formalizzati?	FAIL	Manca un processo di Change Management o un comitato tecnico (CAB). Le variazioni infrastrutturali avvengono estemporaneamente "su richiesta", escludendo il Board da qualsiasi analisi d'impatto preventivo.
	PR.IP-4: I backup dei dati sono eseguiti e verificati periodicamente?	PASS	L'IT esegue backup regolari e conduce periodicamente test di Disaster Recovery. (Nota di Audit: Mancano una Retention Policy formalizzata e l'evidenza di un isolamento logico/fisico dei salvataggi come AirGap, esponendoli a cifratura simultanea in caso di ransomware).
	PR.IP-5: Le policy sulla sicurezza fisica e ambientale degli asset sono rispettate?	FAIL	A fronte delle misure di sorveglianza fisiche implementate sul campo, si rileva la totale assenza di una policy formale scritta e strutturata che regolamenti la sicurezza perimetrale dei laboratori e dei centri di ricerca.
	PR.IP-6: La distruzione dei dati viene eseguita in conformità con policy aziendali?	FAIL	Coerentemente con le carenze nell'asset lifecycle, non sono stabiliti criteri, software di wipe certificati o metodologie formali per garantire la distruzione definitiva dei dati sui supporti obsoleti.
Maintenance (PR.MA)	PR.MA-1: La manutenzione e il patching dei sistemi sono eseguiti regolarmente?	FAIL	L'immagine iniziale SOE sicura non è supportata nel tempo. Manca un sistema centralizzato di Patch Management sui dispositivi distribuiti e non viene eseguito alcun Vulnerability Assessment periodico sulla rete interna.
	PR.MA-2: La manutenzione remota da parte di terzi è autorizzata e tracciata nei log?	FAIL	Gli accessi dei manutentori esterni avvengono senza MFA e semplicemente "su richiesta". Le sessioni non vengono centralizzate, verificate o registrate in un sistema di log, impedendo la tracciabilità delle azioni.

CORE CATEGORY 3: DETECT (DE)

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
Anomalies and Events (DE.AE)	DE.AE-1: Baseline del traffico di rete e dei flussi di dati ordinari definita e gestita?	FAIL	Anche se l'IT dispone di diagrammi di rete aggiornati, non viene effettuata alcuna profilazione del traffico o definizione di una baseline dei flussi di dati ordinari. L'assenza di un SIEM impedisce di rilevare anomalie comportamentali o scostamenti rispetto alla normale operatività.
	DE.AE-2: Eventi rilevati analizzati per comprendere i target e i metodi d'attacco?	FAIL	La gestione degli eventi è puramente reattiva. L'IT si limita a rispondere in modo estemporaneo agli allarmi dell'antivirus locale (Microsoft Defender), senza un processo strutturato o competenze interne per analizzare le tattiche (TTPs), i vettori o i target specifici degli attacchi.
	DE.AE-3: Log e dati degli eventi aggregati e correlati da più fonti e sensori?	FAIL	L'organizzazione non dispone di una soluzione SIEM. I log generati dai firewall Palo Alto, da Active Directory e dagli ambienti cloud (Azure e Office 365) rimangono isolati sui singoli sistemi senza alcuna correlazione centralizzata.
	DE.AE-4: Impatto effettivo degli eventi di sicurezza determinato?	FAIL	L'organizzazione non possiede policy di classificazione delle informazioni né un framework strutturato di data governance. Di conseguenza, in caso di anomalia o potenziale attacco, è impossibile determinare tempestivamente l'impatto reale o la gravità dell'evento sugli asset critici.
	DE.AE-5: Soglie di allerta (thresholds) stabilite per la notifica degli incidenti?	FAIL	Non sono definite soglie di allerta per la generazione automatica di allarmi né procedure formalizzate di escalation gerarchica. Gli incidenti vengono gestiti "as they come" dall'unico analista di sicurezza, il quale riporta direttamente all'IT Manager.
Security Continuous Monitoring (DE.CM)	DE.CM-1: Rete aziendale monitorata attivamente per rilevare potenziali incidenti?	FAIL	Nonostante la presenza di firewall Palo Alto Next-Gen configurati e aggiornati dal team di rete, non viene eseguito un monitoraggio attivo del traffico orientato alla rilevazione tempestiva degli incidenti in tempo reale, a causa dell'assenza di un SIEM o di un SOC/MSSP.
	DE.CM-2: Ambiente fisico monitorato per rilevare potenziali incidenti di sicurezza?	PASS	Ottima postura di sicurezza fisica. Aetheris Therapeutics S.p.A. gestisce una struttura altamente sicura con telecamere TVCC attive 24/7, monitoraggio continuo dei laboratori di ricerca e delle strutture fisiche, abbinato a un approfondito processo di vetting per tutti i dipendenti.
	DE.CM-3: Attività del personale interno monitorate per rilevare comportamenti anomali?	FAIL	Non viene eseguito alcun monitoraggio sulle attività degli utenti per rilevare comportamenti anomali o insider threats. Inoltre, le credenziali dell'account amministrativo sono condivise stabilmente tra più membri senior dell'IT, annullando l'accountability individuale e la tracciabilità delle azioni.
	DE.CM-4: Codice malevolo (malware/ransomware) rilevato tempestivamente?	FAIL	Il rilevamento del malware è demandato esclusivamente all'antivirus locale (Microsoft Defender) configurato sui singoli endpoint. Manca una soluzione di telemetria centralizzata (EDR/XDR) o un controllo centralizzato in grado di intercettare e bloccare la propagazione laterale delle minacce in tempo reale.

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
	DE.CM-5: Esecuzione di codice mobile non autorizzato sugli endpoint rilevata?	FAIL	Non sono implementati filtri o sistemi di sandboxing della posta elettronica e del traffico web per intercettare ed eventualmente bloccare codice mobile malevolo prima dell'esecuzione, affidandosi unicamente all'antivirus locale dei laptop.
	DE.CM-6: Attività dei provider di servizi esterni (terze parti) monitorate?	FAIL	Non si effettua alcuna attività di Third-Party Risk Management. Le attività dei provider esterni non vengono monitorate dal punto di vista della sicurezza né sottoposte ad audit.
	DE.CM-7: Monitoraggio per individuare accessi, dispositivi o software non autorizzati effettuato?	FAIL	Nonostante la rete sia segmentata tramite VLAN, non è presente un sistema di Network Access Control (NAC) per impedire il collegamento fisico di dispositivi abusivi alla rete. Si rileva inoltre l'assenza totale di soluzioni DLP e di controlli sullo Shadow IT o hardware non registrato.
	DE.CM-8: Vulnerability scan eseguiti regolarmente?	FAIL	Sebbene sia stato acquistato lo scanner Qualys, lo strumento viene utilizzato dal team IT esclusivamente su base estemporanea ("ad-hoc"). Non esiste un programma formale di vulnerability management, lasciando irrisolto un gran numero di vulnerabilità classificate come "high" e "severe".
Detection Processes (DE.DP)	DE.DP-1: Ruoli e responsabilità per la detection ben definiti per garantire l'accountability?	FAIL	I ruoli e le responsabilità relativi alla sicurezza informatica e al monitoraggio degli incidenti non sono formalizzati né documentati. Le attività operative sono delegate in blocco all'IT, e l'unico analista opera solo in modalità "antincendio" e reattiva.
	DE.DP-2: Processi di detection conformi a tutti i requisiti normativi e legali applicabili?	FAIL	Le attività di rilevamento non sono mappate né verificate rispetto ai requisiti legali, regolamentari o contrattuali (mancano policy sul trattamento dei dati, registri o criteri di data governance). L'azienda opera in assenza totale di un framework o processo di rischio tecnologico.
	DE.DP-3: Processi e sistemi di rilevamento testati periodicamente?	FAIL	Sebbene vengano eseguiti test periodici di Disaster Recovery sui backup e sulla continuità operativa, non viene effettuato alcun test di efficacia specifico sui sistemi o sui processi di detection (es. simulazioni d'attacco, cyber drills o penetration test).
	DE.DP-4: Informazioni sul rilevamento degli eventi comunicate tempestivamente alle parti interessate?	FAIL	Manca un processo formale d'incident management e non sono definiti canali strutturati di escalation. Di conseguenza, le informazioni sulle minacce o sugli eventi di sicurezza rilevati non vengono comunicate in modo sistematico al Board o a partner critici esterni.
	DE.DP-5: Processi di detection migliorati continuamente?	FAIL	Non esiste un processo formale di post-incident review o di analisi delle "Lessons Learned" (lezioni apprese) in seguito a un attacco. Le attività operative rimangono limitate alla gestione reattiva delle sole emergenze quotidiane.

CORE CATEGORY 4: RESPOND (RS)

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
Response Planning (RS.RP)	RS.RP-1: Piani di risposta agli incidenti eseguiti durante e dopo un evento di sicurezza?	FAIL	Aetheris Therapeutics S.p.A. non possiede alcun piano formale di Incident Response (IRP). L'organizzazione gestisce gli eventi in modalità puramente "antincendio" ed estemporanea attraverso l'unico analista di sicurezza, senza una procedura documentata o strutturata.
Communications (RS.CO)	RS.CO-1: Il personale conosce ruoli e ordine di operazioni in caso di risposta a un incidente?	FAIL	I ruoli e le responsabilità per la risposta agli incidenti non sono definiti né comunicati. Le attività sono delegate genericamente al team IT, mancando una struttura di comando, matrici RACI o punti di contatto operativi chiariti.
	RS.CO-2: Incidenti segnalati e notificati in conformità a criteri formali ed escalation stabilite?	FAIL	Mancano criteri di classificazione della gravità degli incidenti e soglie di escalation gerarchica. Gli eventi non vengono notificati in modo sistematico al Board o all'IT Manager, ma gestiti "as they come" dall'analista locale.
	RS.CO-3: Condivisione delle informazioni eseguita in conformità con i piani di risposta?	FAIL	In assenza di un piano d'incidente, non esistono linee guida formali per il coinvolgimento di forze dell'ordine, autorità regolatorie (es. Garante Privacy per violazioni GDPR) o consulenti legali esterni durante un data breach.
	RS.CO-4: Coordinamento con gli stakeholder interni ed esterni mantenuto durante la risposta?	FAIL	Non sono previste procedure d'interfaccia verso i provider SaaS terzi o verso i business leader interni durante un'interruzione di servizio o una compromissione di dati critici.
	RS.CO-5: Condivisione volontaria di threat intelligence con community o colleghi di settore?	FAIL	Aetheris Therapeutics S.p.A. non partecipa ad alcun ISAC, CSIRT di settore o rete di condivisione delle informazioni sulle minacce cyber. L'azienda opera in completo isolamento informativo.
Analysis (RS.AN)	RS.AN-1: Notifiche e alert dai sistemi di rilevamento investigati e analizzati?	FAIL	L'analisi delle minacce si limita alla reazione manuale estemporanea ad avvisi locali di Microsoft Defender. Manca una copertura di monitoraggio 24/7, un SIEM centralizzato o un processo di triaging degli allarmi.
	RS.AN-2: Impatto dell'incidente analizzato e documentato in base alla criticità?	FAIL	L'assenza di un quadro di data governance e classificazione delle informazioni impedisce di quantificare e documentare la portata reale, l'impatto economico o la perdita reputazionale a seguito di un incidente.
	RS.AN-3: Capacità ed attività di Digital Forensics eseguite quando necessario?	FAIL	Il team non possiede le competenze specialistiche, le procedure o gli strumenti software adeguati per condurre indagini forensi digitali e preservare la catena di custodia delle prove a seguito di una violazione.
	RS.AN-4: Incidenti categorizzati e prioritizzati in conformità ai piani di risposta?	FAIL	Non esistono criteri o matrici per la categorizzazione degli incidenti in base a gravità e urgenza. Tutte le anomalie segnalate dall'antivirus vengono affrontate con il medesimo livello di priorità operativa.
Mitigation (RS.MI)	RS.MI-1: Azioni di contenimento eseguite per prevenire l'espansione dell'evento?	FAIL	Non vengono applicati standard di contenimento strutturati (es. SANS/NIST). L'assenza di strumenti EDR/XDR centralizzati rende impossibile il blocco del movimento laterale o l'isolamento remoto tempestivo dell'host compromesso.

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
	RS.MI-2: Effetti degli incidenti mitigati ed eradicati dai sistemi interessati?	FAIL	L'eradicazione si limita a interventi locali manuali (ripristino/re-image del laptop), senza procedure formali per verificare la completa rimozione dell'infezione o la persistenza degli attaccanti sulla rete aziendale.
	RS.MI-3: Nuove vulnerabilità identificate durante l'evento colmate o documentate?	FAIL	Manca un programma continuo di Vulnerability Management. Le scoperte di Qualys non alimentano un processo prioritario di remediating/patching e non esiste una procedura per gestire o mitigare le vulnerabilità Zero-Day.
Improvements (RS.IM)	RS.IM-1: I piani di risposta incorporano le lezioni apprese (Lessons Learned)?	FAIL	Non vengono organizzate sessioni formali di post-incident review o debriefing al termine delle emergenze. L'organizzazione perde l'opportunità di convertire gli errori passati in miglioramenti procedurali.
	RS.IM-2: Le strategie di risposta vengono aggiornate e testate periodicamente?	FAIL	In assenza di un Incident Response Plan scritto, non si effettuano test di simulazione d'attacco (es. Tabletop Exercises o Cyber Drills) per valutare o aggiornare le capacità di reazione aziendali.

CORE CATEGORY 5: RECOVER (RC)

SOTTO-CATEGORIA	OBIETTIVO DEL CONTROLLO / DOMANDA	ESITO	MOTIVAZIONE TECNICA (EVIDENZE DI AUDIT)
Recovery Planning (RC.RP)	RC.RP-1: I piani di Disaster Recovery e ripristino vengono eseguiti durante o dopo un evento?	PASS	Il team IT dispone di piani di continuità operativa documentati, esegue regolarmente backup e conduce test periodici di Disaster Recovery sui salvataggi dati. (Nota di audit: occorre integrare l'isolamento logico/ AirGap contro il ransomware).
Improvements (RC.IM)	RC.IM-1: I piani di ripristino incorporano le lezioni apprese dagli incidenti passati?	FAIL	Sebbene i test di DR siano svolti su base operativa, non esiste un processo formalizzato di "Lessons Learned" per aggiornare i piani d'emergenza in risposta a nuove tipologie di incidenti o attacchi complessi.
	RC.IM-2: Le strategie e i piani di ripristino vengono aggiornati regolarmente a seguito dei test?	FAIL	I piani di Business Continuity dell'IT sono focalizzati sui guasti infrastrutturali classici, senza incorporare scenari di ripristino da attacchi ransomware estesi o la gestione delle dipendenze da SaaS critici esterni.
Communications (RC.CO)	RC.CO-1: La gestione della comunicazione e delle Public Relations (PR) è definita per tutelare la reputazione?	FAIL	Manca un piano aziendale di crisi e comunicazione di PR. In caso di grave fuga di dati o downtime prolungato, non sono definite linee guida per tutelare il brand, la reputazione aziendale e le relazioni pubbliche.
	RC.CO-2: Le attività di ripristino e la ripresa dei servizi sono comunicate agli stakeholder interni ed executive?	FAIL	Non esistono flussi o protocolli di comunicazione formalizzati per informare l'Executive Board, la direzione o i responsabili di business sullo stato di avanzamento del ripristino dei sistemi critici.
	RC.CO-3: Le relazioni reputazionali e la fiducia degli stakeholder vengono gestite dopo un evento grave?	FAIL	Non sono previste strategie o azioni di mitigazione post-incidente rivolte a clienti, partner industriali o autorità di regolamentazione per ripristinare la trasparenza e la fiducia nell'organizzazione.